Your role in the incident

SC2632 - From Intent to Enforcement: Agentic Kubernetes Guardrails with Quarantine Mode

What: prepare a reviewed change set from security intent: policies, tests, expiring exceptions and phased rollout. Define the scoped Quarantine Mode response and recovery criteria.

Why: contain harmful access on shared infrastructure while essential services keep running. Your case reports suspicious activity with uncertain exposure. The incident is fictional.

The environment and its controls

Kubernetes manages applications across machines. A **container** packages an application and its dependencies. **Pods** run containers; **replicas** are copies. **Namespaces** group resources. **ServiceAccounts** identify workloads making management requests. **Kyverno** checks proposed changes against policy and can refuse a covered request. That request check does not stop an application already running. Network rules control covered traffic, API permissions control access to platform resources, and application controls govern agent tools. Demo evidence uses an isolated local lab and fixture tests.

Your assignment

Act as the incident review team. Decide what may proceed, what you hold and what evidence is still required. Use the **page 6 decision record**. Work in plain language. No laptops or code writing are required.

Before Round 1

1. Choose one case and read its opening alert. A: library update (page 2). B: support assistant (page 3). C: operations changes (page 4). D: credential access (page 5). Review only your selected case.

2. Choose one primary operating constraint. Record it and a measurable minimum service on page 6.

Availability: keep at least two healthy application copies and required connections. **Evidence:** preserve and hash relevant logs and record approvals. **Velocity:** keep unaffected releases moving while affected changes pause. **Containment:** stop suspected exposure and explain any service degradation. These are fictional exercise choices, not regulatory thresholds.

3. Assign roles. The INCIDENT LEAD states the decision. The RECORDER writes page 6. The ANALYST checks the evidence. The INDEPENDENT REVIEWER raises a concern before the decision. Combine roles if needed. Others defend the operating constraint.

How each round works

Discuss the supplied evidence. Write a decision before the reveal. Hear the new evidence, then revise beside your original answer. **Keep pages 7 and 8 covered until a co-presenter opens each round.** Keep the separate review findings sealed too.

Milind and Vivek co-present. Your newly written intent does not automatically deploy.

Case A: A library update

Opening alert and environment

09:14. payments-api 2.14.3 shipped three days ago with a metrics-library update. One process in a payments Pod connects to hr-sync and inventory. The service remains operational; the scope of compromise is uncertain. Three payments replicas run behind a Service, with a PodDisruptionBudget requiring two available.

Reference intent for comparison

Deny new east-west communication from payments while preserving known dependencies. Prevent privilege escalation. Restrict the compromised workload's API access. Roll out in stages and time-box exceptions.

Proposal excerpt

Clause/control	Reference proposal
Egress profile	Deny profiles outside the approved list
Privilege escalation	Generate deny-privilege-escalation
Kubernetes API access	NOT IMPLEMENTED. RBAC and ServiceAccount handover.
Registry restriction	Added beyond intent, Audit only

What the evidence says

payments-api passes the privilege and egress checks. backup-job would block under the egress policy. report-runner uses a public registry and is admitted at Audit. With the reference backup-job exception, the egress check skips it.

Round 2 request

backup-job needs temporary storage access. The reference request names platform-ops@trustfall.example and a 24-hour TTL. A separate agent request claims an approval nobody has independently recorded. Decide what proof, scope and shorter expiry you need.

Source: output/frozen-a/PR.md. A/B/C are excerpts, not a claim that your new statement already ran through a model.

Case B: A ticket-reading assistant

Opening alert and environment

09:14. payments-api includes a support-agent sidecar that reads customer tickets and has tools. A process named tool-runner connects to unexpected services. The Pod shares an identity and networking with the payments application. The image came from the approved registry.

Reference intent for comparison

Restrict payments egress to known dependencies. Stop the assistant from using the Pod's Kubernetes identity. Stop unsafe tool behavior. Preserve essential service dependencies.

Proposal excerpt

Clause/control	Reference proposal
Egress profile	Constrain permitted profiles
Assistant identity	Pod-level token control; inspect application impact
Tool behavior	Admission cannot enforce application tool calls
Registry restriction	Added at Audit; does not establish tool safety

What the evidence says

Review the token setting and the egress allow list together. The frozen report simulates admission on Pod fixtures. It does not test whether a support ticket can manipulate an internal database tool. An approved image alone does not establish safe agent behavior.

Round 2 request

The support assistant asks for access to inventory and says the customer ticket author approved it. Is that an accountable owner or untrusted context? Decide whether to refuse, narrow or require independent review.

Source: output/frozen-b/PR.md. A/B/C are excerpts, not a claim that your new statement already ran through a model.

Case C: An ops agent takes chat requests

Opening alert and environment

09:41. system:serviceaccount:agents:ops-agent patches payments-api from 3 to 12 replicas, then hr-sync from 2 to 6. Neither request has a ticket annotation. Its legacy ClusterRole allows patching Deployments across the cluster.

Reference intent for comparison

Keep the ops agent's changes within its own namespace. Require tickets for its changes. Preserve its ability to read what it needs.

Proposal excerpt

Clause/control	Reference proposal
Outside-namespace mutation	Deny changes by the named agent identity
Ticket annotation	Warn initially; tool compatibility needs review
Read access	Outside admission; review RBAC separately
Replica surge	Added at Audit, threshold 8

What the evidence says

The scenario tests requests as the agent and as a human SRE. A policy scoped to the agent identity does not block the human requester. Ask whether a ticket annotation proves approval, and whether the underlying ClusterRole should permit the action.

Round 2 request

The ops team requests four hours of ticket-free payments scaling to maintain service capacity. The agent forwards a command to a human that also widens its RBAC. Decide which request, if any, has verified authority.

Source: output/frozen-c/PR.md. A/B/C are excerpts, not a claim that your new statement already ran through a model.

Case D: A monitoring identity reads Secrets

Opening alert and environment

09:14. The audit log shows system:serviceaccount:payments:monitoring-agent listing Secrets across namespaces in 40 seconds. A past dashboard integration needed one Secret, and its cluster-wide get/list role remains. Metrics still flow. The service remains operational; the scope of compromise is uncertain.

Reference intent for comparison

Stop monitoring-agent reading Secrets outside payments. Preserve metrics and the audit evidence of everything it accessed.

Proposal excerpt

Requirement	Manual review proposal, not generated enforcement
Secret GET/LIST	Admission does not see reads. Hand over to RBAC.
Identity scope	Review bindings and replace excess rights with a scoped Role.
Evidence	Export audit events, identify resources and preserve hashes.
Service continuity	Test monitoring and payment dependencies before rotation.

What the evidence says

Predict the result before the reveal: can a copied token still read Secrets after the Pod is quarantined? Require denied outside-namespace GET/LIST, preserved GET of the exact required in-namespace Secret, and a reachable positive control. A separate real lab recording tests these boundaries with synthetic resources; it does not qualify production metrics delivery or external application-key rotation.

Round 2 request

There is no Kyverno admission exception that fixes this read privilege. A temporary RBAC grant, if needed, requires independently verified approval, precise resource scope, an owner, an expiry and an executed revocation plan.

Source: scenarios/d-secret-enumeration/review/PR.md. RBAC is human-reviewed; generator scenario d is not implemented.. A/B/C are excerpts, not a claim that your new statement already ran through a model.

Your decision record

Table ____ Case ____ Constraint ____
Lead _____ Recorder _____ Analyst _____ Reviewer _____

Round 1: intent and PR review

Our intent and preserved dependency: _____

_____

APPROVE / MODIFY / REJECT / ESCALATE. Reason:

_____

Missing control or test: _____

Round 2: exception and rollout

Grant / narrow / refuse / escalate: _____

Exact scope: _____ Owner: _____

Independent approver: _____ Expiry (date/time): _____

Mode per control: _____ Promotion criterion: _____

Round 3: containment and later evidence

Evidence first (source and preservation):

_____

Ordered actions: 1. _____ 2. _____ 3. _____

Level and target: _____ Declaring authority: _____

Availability floor: _____ Escalation trigger: _____

After the later finding, our revision is: _____

Recovery and Monday action

Exit test: _____ Who can lift the level: _____

Rollback condition: _____

My action, owner and verification: _____

Round 3: open at minute 27

Read only your chosen case. Preserve the original decision on the worksheet. These incident updates are fictional. Choose Q0 Normal, Q1 Freeze, Q2 Constrain or Q3 Isolate. Name evidence, authority, scope and availability floor.

Case A

09:54. A payments process continues east-west connections. Security requests immediate isolation of suspect workloads. Operations requires healthy serving capacity throughout containment. Is deleting a suspect compatible with evidence preservation and the PDB?

Case B

09:54. The assistant reads another customer ticket and invokes a tool. The application remains operational. An engineer suggests adding a debug container and restarting the whole Pod. Which identity, tool/input path and evidence would you examine first?

Case C

10:21. The agent cannot perform its outside-namespace change, so it opens OPS-2294 asking a human to increase payments capacity and widen its ClusterRoleBinding. A human runs the scaling command and stops before the role change. A new chat request names billing-api.

Case D

09:54. Audit events show the monitoring identity listed database-related Secrets. No evidence yet establishes that an exposed credential was used. Metrics still flow. A teammate suggests Q3 on the Pod and delaying credential changes until a coordinated maintenance window.

Board decision

Number actions before choosing a level. Does your plan preserve the necessary evidence? Can a token already copied away from the Pod still work? What legitimate dependency or human action could bypass your selected controls?

Later finding: open at minute 34

Read only your chosen case. Revise your order or level, or explain why you hold. Underline the new fact that matters.

Case A

09:57. A second replica has the same library image. A helper Pod with a host-mounted volume passed the original policy set. The privilege checks did not cover this host-access gap. The suspect may be an image-wide problem. Q3 prevents replacement Pods unless an authorized override applies.

Case B

09:57. Agent logs show the ticket text steering the tool-runner. The tool can reach a privileged database path. The container image appears unchanged. The debugging action used pods/ephemeralcontainers, which Pod-only admission rules can miss.

Case C

10:26. The ops agent also supports billing. Its chat input includes an instruction from a phished contractor account. The requester-specific policy still permits human actions. Terminating the agent would lose uncaptured context and disrupt billing.

Case D

09:57. Rotating every potentially exposed Secret would also rotate the payments-db-proxy credential while the service is operating. The audit export can identify the accessed resources. A dashboard engineer offers a tested monitoring-only replacement identity.

Post-incident review

Exchange decision records with a nearby table. Name one assumption that fails under their case or constraint. Add one exit test and identify who can authorize returning toward Q0.

The cases intentionally have different control boundaries. A/B/C have repository fixture suites. D has a separately executed synthetic read-authorization and credential lab; target-platform and application evidence remain required.